

Nahamcon 2020 Crypto - Docxor

deuterium — 2020-06-14

Canonical HTML: <https://deut-erium.github.io/WriteUps/2020/nahamconCTF/crypto/Docxor/2020-06-14-Nahamcon-2020-Docxor.html>

Abstract

CTF writeup: ZIP magic bytes earn their wizard hat in NahamCon 2020's Docxor: recover a four-byte XOR key from the header and restore the document.

Docxor

Challenge

189 Solves



Docxor

75

My friend gave me a copy of his homework the other day... I think he encrypted it or something?? My computer won't open it, but he said the password is only four characters long...

Download the file below.

 homework

Flag

Submit

Getting hints from the name, one could tell, it is XOR and its about a doc.

Still, first thing to consider is running the file command to see whats the homework file is about

```
file homework
homework: data
```

Cool! this means, the homework file is simply XOR encryption of a .doc file with 4 byte key. But hey that should ring bells since the first few bytes are file signature also called magic bytes sometimes.

Using the magic bytes, we can recover the xor key and hence the full document after xoring with the xor key.

			zip	
			aar	
			apk	
			docx	
			epub	
50 4B 03 04			ipa	
			jar	
			kmz	
			maff	
50 4B 05 06	PK..	0	odp	
(empty archive)			ods	
			odt	
50 4B 07 08			pk3	
(spanned archive)			pk4	
			pptx	
			usdz	
			vsdz	
			xlsx	
			xpi	
				zip file format and formats based on it, such as EPUB, JAR, ODF, OOXML

The magic bytes we seek are 50 4B 03 04. The first four bytes of the homework are 0a0a 9abf, the xor key should be $0a0a9abf \oplus 504b0304 = 5a4199bb$ Lets write a quick script.

```
from pwn import xor

with open('homework', 'rb') as homework_file:
    homework_data = homework_file.read()

HEADER = homework_data[0:4]
MAGIC = b"\x50\x4B\x03\x04"
XOR_KEY = xor(HEADER, MAGIC)

with open('decrypted.doc', 'wb') as decrypted:
    decrypted.write(xor(XOR_KEY, homework_data))
```

This produces decrypted.doc which when opened looks like

```
flag{xor_is_not_for_security}
```

flag-xor-is-not-for-security"

Interactive controls are omitted from this PDF. See the canonical HTML version.